

ITA1412 - ETHICAL HACKING

CO4 ASSESSMENT TOOL 3

Name: K. Tejasri

Reg no: 192371019

1. E-Commerce Linux Web Server: Security Review

Aim: To evaluate the security posture of an authorized Linux-based e-commerce web server, identify important weaknesses, assess their possible consequences, and propose practical defensive controls.

Algorithm: 1. Establish authorization and scope. 2. Identify hosts, services and trust boundaries. 3. Perform reconnaissance. 4. Conduct vulnerability assessment. 5. Validate selected findings safely. 6. Determine confidentiality, integrity and availability impact. 7. Prioritize remediation. 8. Prepare the security report.

Procedure: Define the permitted target, testing period and evidence requirements. Collect technology and service information using low-impact reconnaissance. Review the web server for obsolete packages, unnecessary resources, unsafe configuration and exposed interfaces. Inspect application inputs for validation weaknesses. Confirm findings only with harmless checks in an isolated laboratory. Record observations and recommend controls at server, application and network layers.

Observation: The environment may be exposed through obsolete server components, unnecessary files or services, weak input handling, inadequate authentication and excessive network exposure. Limited application-layer filtering can also reduce the ability to detect common web attacks.

2. Financial Application: Database Injection and Browser-Script Security

Aim: To examine an authorized financial web application for SQL injection and cross-site scripting risks, determine their effect on the CIA triad, and recommend secure coding and monitoring practices.

Algorithm: 1. Confirm authorization. 2. Map important application functions. 3. Identify input parameters. 4. Perform controlled security testing. 5. Validate suspected weaknesses without accessing real records. 6. Assess business and CIA impact. 7. Recommend corrective controls. 8. Document evidence.

Procedure: Review login, account and transaction functions. Capture representative requests using an approved proxy such as Burp Suite or OWASP ZAP. Inspect responses for unsafe reflection and excessive error information. Use automated SQL injection detection only against the designated laboratory application. Test XSS with harmless markers and verify that contextual output encoding is applied. Assess authentication and session protection.

Observation: SQL injection risk increases when application input is combined with database queries without safe parameterization. XSS risk occurs when untrusted content reaches a browser without suitable context-specific encoding. Detailed database errors can also reveal implementation information.

3. Corporate Wireless Network: Rogue Access Point Assessment

Aim: To assess the risk of an Evil Twin or rogue access point in an authorized corporate wireless environment and strengthen wireless authentication, monitoring and user awareness.

Algorithm: 1. Define the approved wireless scope. 2. Record expected SSIDs and security settings. 3. Passively inspect authorized captures. 4. Compare legitimate and suspicious access-point characteristics. 5. Review authentication and segmentation. 6. Assess business impact. 7. Recommend preventive and detective controls. 8. Document the assessment.

Procedure: Establish the legitimate wireless baseline. Use Wireshark to examine authorized captures for duplicate SSIDs, unusual BSSID behavior and authentication anomalies. In an isolated lab, use wireless assessment tools to study security configuration without collecting real credentials. Check password strength, certificate validation, client isolation and network segmentation.

Observation: An Evil Twin takes advantage of a trusted network name. If clients do not adequately verify the wireless infrastructure, they may connect to an unauthorized access point, increasing the risk of traffic interception or manipulation where application protections are weak.

4. Wireless-to-Web Application Attack Path

Aim: To evaluate how weaknesses in an internal wireless network could combine with weaknesses in an employee web application, and to identify controls that interrupt the attack path at multiple stages.

Algorithm: 1. Establish scope. 2. Map wireless and application assets. 3. Perform authorized reconnaissance. 4. Assess network exposure. 5. Review application authentication and authorization. 6. Analyze the combined attack path. 7. Identify control points. 8. Report remediation priorities.

Procedure: Identify the laboratory wireless network and test application. Perform approved host and service discovery. Use Nmap and WhatWeb for technology identification. Map application endpoints and sessions with Burp Suite or OWASP ZAP. Check access-control behavior using test accounts. Verify that network segmentation prevents wireless clients from reaching protected resources. Document the attack chain conceptually rather than using real employee data.

Observation: A weak wireless credential can provide initial network access, after which an attacker could discover internal services and search for application weaknesses. Poor authentication, session handling or authorization can then increase the impact. Strong controls at any stage can break the chain.

5. University Wireless Availability: Deauthentication DoS Assessment

Aim: To study the security and availability impact of repeated wireless deauthentication events in an authorized laboratory and recommend controls that improve resilience and detection.

Algorithm: 1. Define the test environment. 2. Identify affected access points. 3. Inspect authorized wireless captures. 4. Correlate management-frame activity with AP logs. 5. Measure availability impact. 6. Review wireless security configuration. 7. Recommend defensive controls. 8. Document evidence and response procedures.

Procedure: Establish the approved wireless test environment and identify the access points under review. Analyze authorized captures with Wireshark for repeated deauthentication or disassociation frames. Use wireless analysis tools only in the isolated lab. Compare packet observations with access-point logs and user-disconnection reports. Review Protected Management Frames, WPA3 support, WIDS/WIPS and AP configuration.

Observation: Repeated deauthentication events can cause clients to disconnect and reduce network availability. In a university environment, this may interrupt classes and services. Any simulation should remain restricted to test devices and an isolated laboratory.

Overall Conclusion

The five assessments show that web, wireless and network weaknesses can interact to create multistage security risks. A strong defense should combine secure authentication, network segmentation, hardened servers, secure application development, strict access control, continuous monitoring, timely patching and tested incident-response procedures. All active security testing must remain within explicitly authorized and isolated environments.

Suggested Submission Evidence

- Authorized reconnaissance and vulnerability-assessment screenshots.
- Burp Suite or OWASP ZAP request/response evidence for web testing.
- Nmap, WhatWeb or Nikto results where appropriate.
- Wireshark analysis of authorized wireless captures.
- Vulnerability tables containing severity, impact and remediation.
- An attack-chain or architecture diagram showing defensive control points.
- A final prioritized remediation plan.

Finding	Severity	Impact	Recommendation
Unsupported server components	High	Known flaws may increase the chance of unauthorized access.	Maintain supported versions, patch regularly and remove obsolete packages.
Exposed administrative resources	Medium–High	Attackers may discover sensitive configuration or management pages.	Restrict access, remove unnecessary resources and enforce least privilege.
Unsafe input processing	High	Malicious input may affect application behavior or user data.	Validate input, use parameterized operations and encode output.
Limited application filtering	Medium–High	Common web attacks may receive less preventive filtering.	Deploy and properly tune a WAF as an additional security layer.
Insufficient monitoring	High	Suspicious activity may remain unnoticed for longer.	Centralize logs, create alerts and correlate events through SIEM.

Finding	Severity	Impact	Recommendation
Unsafe database query construction	Critical/High	Unauthorized reading or alteration of database information may become possible.	Use prepared statements, restricted database accounts and safe error handling.
Stored or reflected script injection	High	A user's browser may execute attacker-controlled content.	Apply contextual output encoding, validation and an appropriate CSP.
Verbose database errors	Medium	Schema or implementation details may be disclosed.	Show generic errors to users and retain detailed records securely on the server.

Finding	Severity	Impact	Recommendation
Weak session protection	High	Session misuse may increase account compromise risk.	Use Secure and HttpOnly cookies, suitable SameSite settings, rotation and expiration.

Finding	Severity	Impact	Recommendation
Shared wireless key	High	A common password is difficult to attribute and rotate for individuals.	Use WPA2-Enterprise or WPA3-Enterprise with 802.1X.
Unauthorized access point	High	Users may connect to attacker-controlled infrastructure.	Maintain approved-AP inventories and deploy WIDS/WIPS.
Inadequate certificate checking	High	Users may accept fraudulent authentication infrastructure.	Use managed client profiles and enforce certificate validation.
Weak network separation	High	A compromised wireless client may reach sensitive systems.	Separate guest, employee, IoT and critical networks.
Limited user awareness	Medium	Users may trust unexpected login prompts or duplicate SSIDs.	Train users to recognize and report suspicious wireless behavior.

Finding	Severity	Impact	Recommendation
Weak wireless credentials	High	Unauthorized devices may gain network access.	Use enterprise authentication, strong identity controls and secure credentials.
Flat internal network	Critical	Wireless compromise may expose internal applications.	Use VLANs, ACLs, firewalls and zero-trust access principles.
Weak authentication/session controls	High	Accounts may be exposed to takeover or misuse.	Implement MFA, secure session rotation, expiration and server-side checks.
Broken access control	Critical	Unauthorized users may access employee information.	Enforce authorization for every protected server-side operation.
Insufficient event monitoring	High	A multistage attack may not be detected promptly.	Centralize network and application logs and correlate alerts.

Finding	Severity	Impact	Recommendation
Unprotected management frames	High	Repeated disconnections may disrupt wireless service.	Enable Protected Management Frames and use WPA3 where appropriate.
No wireless intrusion detection	High	Abnormal activity may continue without timely response.	Deploy WIDS/WIPS and alert on unusual management-frame patterns.
Weak access-point configuration	Medium–High	Poor settings may increase exposure to disruption.	Harden AP firmware, configuration and management interfaces.
Unprepared incident response	Medium	Recovery may take longer and evidence may be incomplete.	Create wireless response procedures and centralize logs.

Related Screenshot Evidence

The following are illustrative laboratory screenshots created for documentation. They use TEST-ONLY targets and do not represent real customer, financial, employee or campus data.

Question 1 – Related Tool Evidence



Figure 1: Related security-assessment evidence for Question 1.

Question 2 – Related Tool Evidence

OWASP ZAP - Illustrative Security Review

Sites / History / Alerts

Alert: Missing security header — Medium

Alert: Reflected input requires output encoding review — High

Request/Response: representative test request captured

Mode: Safe / authorized laboratory testing

Figure 2: Related security-assessment evidence for Question 2.

Question 3 – Related Tool Evidence

Wireshark - Illustrative Wireless Capture

Interfaces / Capture

802.11 Beacon Source: Test-AP Destination: Broadcast

802.11 Authentication Status: observed in authorized capture

Duplicate SSID observation: TEST-CORP-WIFI

Analysis note: compare BSSID, security settings and certificates

Figure 3: Related security-assessment evidence for Question 3.

Question 4 – Related Tool Evidence

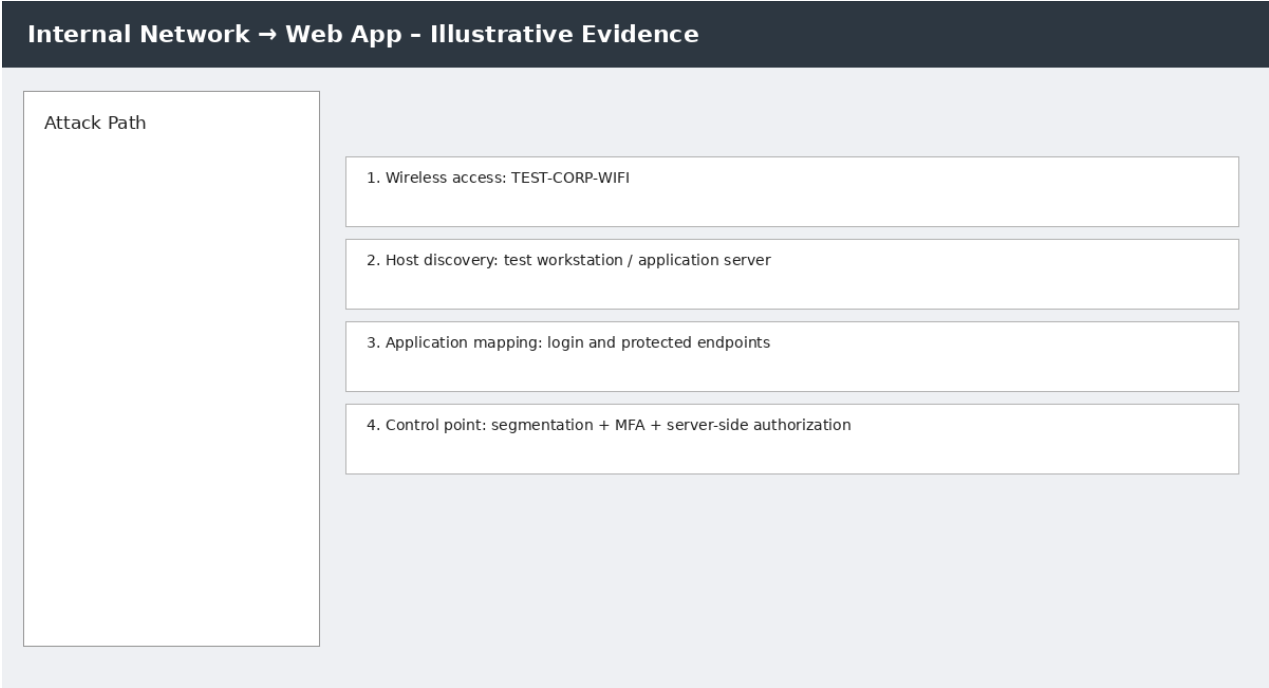


Figure 4: Related security-assessment evidence for Question 4.

Question 5 – Related Tool Evidence

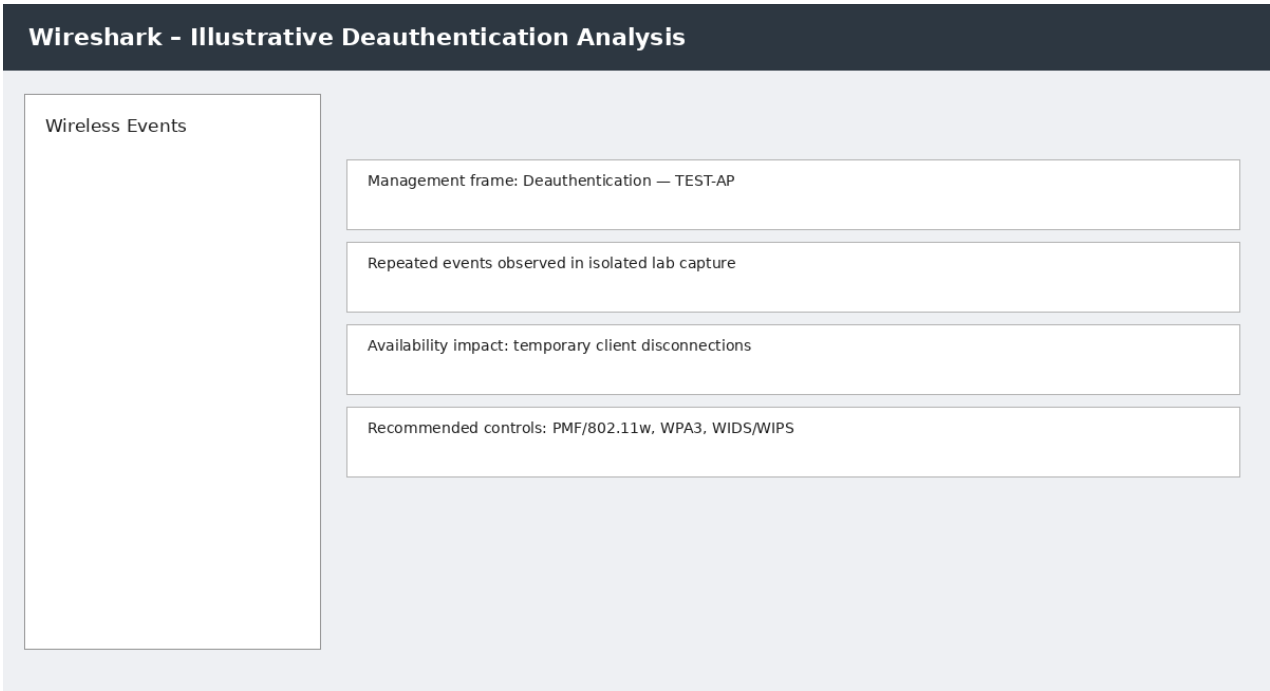


Figure 5: Related security-assessment evidence for Question 5.